

Catalogue Professionnel — 20 Questions de Pré-Évaluation Cybersécurité

Wireless Sensor industriel — EN 18031-1 / IEC 62443-4-1 / IEC 62443-4-2

Ce catalogue constitue une grille de pré-évaluation cybersécurité destinée aux capteurs industriels connectés (wireless sensors) intégrés dans des environnements IACS.

Les questions couvrent les exigences majeures des normes :

- EN 18031-1
- IEC 62443-4-1
- IEC 62443-4-2

Chaque question peut couvrir plusieurs exigences normatives afin de limiter le nombre total de questions tout en gardant une couverture large.

Q1 — Gestion des identités et des comptes

Question

Le produit impose-t-il une identité unique pour chaque utilisateur, service ou équipement, avec suppression des identifiants par défaut et gestion sécurisée des comptes ?

Type

Binary (0/1)

Exigences couvertes

- Identité unique
- Suppression des comptes par défaut
- Gestion des comptes
- Prévention des identifiants statiques
- Contrôle des comptes administrateurs

Normes

- EN 18031-1 AUM-4
- EN 18031-1 AUM-5

- IEC 62443-4-2 IAC

Criticité

Critique

SL cible

SL1 / SL2 / SL3

Q2 — Politique de mots de passe et authentification forte

Question

Le produit applique-t-il une politique de mots de passe robustes avec protection contre le brute force, expiration configurable et authentification multifactorielle pour les accès sensibles ?

Type

Hybrid

- Binary MFA
- Numeric longueur mot de passe
- Numeric tentatives max

Exigences couvertes

- Password policy
- MFA
- Brute force protection
- Lockout
- Validation authenticateurs

Normes

- EN 18031-1 AUM-2
- EN 18031-1 AUM-3
- EN 18031-1 AUM-6
- IEC 62443-4-2 IAC

SL cible

SL2 / SL3

Q3 — Contrôle d'accès et séparation des privilèges

Question

Le produit applique-t-il un contrôle d'accès basé sur les rôles avec séparation des privilèges utilisateurs/administrateurs et restriction des fonctions critiques ?

Type

Binary

Exigences couvertes

- RBAC
- Least privilege
- Séparation privilèges
- Restriction accès fonctions critiques

Normes

- EN 18031-1 ACM
- IEC 62443-4-2 UC

SL cible

SL1 / SL2 / SL3

Q4 — Sécurisation des interfaces et réduction de surface d'attaque

Question

Les ports, services, interfaces réseau, interfaces debug et fonctionnalités non nécessaires sont-ils désactivés ou limités au strict nécessaire ?

Type

Hybrid

- Binary
- Numeric nombre interfaces exposées

Exigences couvertes

- Limitation exposition réseau
- Désactivation services inutiles
- Désactivation debug
- Documentation interfaces
- Hardening

Normes

- EN 18031-1 GEC-2
- EN 18031-1 GEC-3
- EN 18031-1 GEC-4
- EN 18031-1 GEC-5
- IEC 62443-4-2 RDF

SL cible

SL1 / SL2 / SL3

Q5 — Communications sécurisées

Question

Toutes les communications réseau et radio utilisent-elles des protocoles sécurisés assurant confidentialité, intégrité, authenticité et protection contre les attaques replay ?

Type

Binary

Exigences couvertes

- TLS
- Chiffrement
- Intégrité communications
- Authenticité
- Replay protection
- Protocoles sécurisés

Normes

- EN 18031-1 SCM-1

- EN 18031-1 SCM-2
- EN 18031-1 SCM-3
- EN 18031-1 SCM-4
- IEC 62443-4-2 DC
- IEC 62443-4-2 SI

SL cible

SL1 / SL2 / SL3

Q6 — Gestion des clés cryptographiques

Question

Le produit protège-t-il les clés cryptographiques contre l'exposition, le hardcoding et les valeurs statiques tout en permettant leur renouvellement sécurisé ?

Type

Binary

Exigences couvertes

- Key management
- No hardcoded keys
- Key generation
- Secure storage
- Rotation clés

Normes

- EN 18031-1 CCK-1
- EN 18031-1 CCK-2
- EN 18031-1 CCK-3
- EN 18031-1 CCK-4
- IEC 62443-4-2 DC

SL cible

SL2 / SL3

Q7 — Cryptographie moderne

Question

Le produit utilise-t-il des mécanismes cryptographiques conformes aux bonnes pratiques actuelles avec tailles de clés et algorithmes robustes ?

Type

Hybrid

- Binary
- Numeric taille clé

Exigences couvertes

- Best practice cryptography
- Algorithmes robustes
- Taille clés
- Suppression crypto obsolète

Normes

- EN 18031-1 CRY-1
- IEC 62443-4-2 DC

SL cible

SL2 / SL3

Q8 — Stockage sécurisé des données

Question

Les données sensibles, secrets, certificats et paramètres sécurité sont-ils stockés avec protection d'intégrité et de confidentialité ?

Type

Binary

Exigences couvertes

- Secure storage
- Confidentialité données

- Intégrité stockage
- Protection secrets

Normes

- EN 18031-1 SSM-1
- EN 18031-1 SSM-2
- EN 18031-1 SSM-3
- IEC 62443-4-2 DC
- IEC 62443-4-2 SI

SL cible

SL1 / SL2 / SL3

Q9 — Firmware signé et Secure Boot

Question

Le produit vérifie-t-il l'intégrité et la signature du firmware via Secure Boot et empêche-t-il le chargement de firmware non autorisé ?

Type

Binary

Exigences couvertes

- Firmware signing
- Secure boot
- Integrity verification
- Anti-tampering

Normes

- EN 18031-1 SUM-2
- IEC 62443-4-2 SI

SL cible

SL2 / SL3

Q10 — Gestion sécurisée des mises à jour

Question

Les mises à jour locales ou OTA sont-elles authentifiées, sécurisées, vérifiées et documentées avec possibilité de déploiement contrôlé ?

Type

Binary

Exigences couvertes

- OTA secure update
- Update verification
- Update authentication
- Patch delivery
- Update documentation

Normes

- EN 18031-1 SUM-1
- EN 18031-1 SUM-2
- EN 18031-1 SUM-3
- IEC 62443-4-1 Security update management

SL cible

SL2 / SL3

Q11 — Gestion des vulnérabilités et patch management

Question

Le fabricant dispose-t-il d'un processus documenté de gestion des vulnérabilités, de patch management et de correction des CVE critiques ?

Type

Hybrid

- Binary
- Numeric délai correction

- Numeric nombre CVE critiques

Exigences couvertes

- Vulnerability management
- Patch management
- CVE handling
- Security issue management

Normes

- EN 18031-1 GEC-1
- IEC 62443-4-1 Management of security related issues
- IEC 62443-4-1 Security update management

SL cible

SL2 / SL3

Q12 — Journalisation et traçabilité sécurité

Question

Le produit journalise-t-il les événements de sécurité critiques avec protection des logs et possibilité d'export vers un système externe ?

Type

Hybrid

- Binary
- Numeric durée rétention logs

Exigences couvertes

- Security logging
- Audit trail
- Log integrity
- Log export
- Monitoring

Normes

- IEC 62443-4-2 TRE

- EN 18031-1 NMM

SL cible

SL1 / SL2 / SL3

Q13 — Détection et surveillance réseau

Question

Le produit détecte-t-il les comportements anormaux, tentatives d'intrusion, scans réseau ou événements de sécurité suspects ?

Type

Binary

Exigences couvertes

- Network monitoring
- Intrusion detection
- Event detection
- Security alerts

Normes

- EN 18031-1 NMM
- IEC 62443-4-2 TRE

SL cible

SL2 / SL3

Q14 — Résilience et disponibilité

Question

Le produit maintient-il un état sûr en cas d'erreur, surcharge ou attaque de type déni de service tout en protégeant la disponibilité des fonctions critiques ?

Type

Binary

Exigences couvertes

- DoS resilience
- Safe state
- Availability
- Recovery mechanisms

Normes

- EN 18031-1 RLM
- IEC 62443-4-2 RA

SL cible

SL2 / SL3

Q15 — Validation des entrées et protection applicative

Question

Le produit applique-t-il des mécanismes de validation des entrées afin d'empêcher injections, corruption mémoire et traitements non autorisés ?

Type

Binary

Exigences couvertes

- Input validation
- Secure coding
- Protection applicative

Normes

- EN 18031-1 GEC-7
- IEC 62443-4-1 Secure implementation

SL cible

SL2 / SL3

Q16 — Architecture sécurisée et défense en profondeur

Question

Le produit est-il conçu selon une architecture sécurisée intégrant segmentation, trust boundaries et défense en profondeur ?

Type

Binary

Exigences couvertes

- Defense in depth
- Segmentation
- Secure architecture
- Trust boundaries

Normes

- EN 18031-1 Introduction
- IEC 62443-4-1 Secure by design
- IEC 62443-4-2 RDF

SL cible

SL2 / SL3

Q17 — Cycle de développement sécurisé

Question

Le produit suit-il un cycle de développement sécurisé intégrant exigences sécurité, revues de code, vérification et validation sécurité ?

Type

Hybrid

- Binary
- Numeric nombre tests sécurité

Exigences couvertes

- SDL
- Security requirements
- Secure implementation
- Security testing
- Verification & validation

Normes

- IEC 62443-4-1

SL cible

SL2 / SL3

Q18 — Gestion des composants tiers et supply chain

Question

Les composants tiers, bibliothèques logicielles et dépendances sont-ils inventoriés, vérifiés et maintenus à jour ?

Type

Binary

Exigences couvertes

- Third-party component management
- Supply chain security
- Dependency management
- Software inventory

Normes

- IEC 62443-4-1
- EN 18031-1 GEC-1

SL cible

SL2 / SL3

Q19 — Documentation sécurité et hardening

Question

Le produit fournit-il une documentation de sécurité incluant hardening, gestion des comptes, configuration sécurisée et procédures de maintenance ?

Type

Binary

Exigences couvertes

- Hardening guide
- Secure configuration
- Security documentation
- Account management guidance

Normes

- IEC 62443-4-1 Security guidelines
- EN 18031-1 GEC-4

SL cible

SL1 / SL2 / SL3

Q20 — Conformité sécurité globale du capteur industriel

Question

Le capteur industriel sans fil respecte-t-il une stratégie cybersécurité globale couvrant authentification, contrôle d'accès, communications sécurisées, intégrité logicielle, monitoring, mises à jour, résilience et gestion des vulnérabilités ?

Type

Binary

Exigences couvertes

- Security by design
- Global compliance
- IACS cybersecurity

- Defense in depth
- Continuous security

Normes

- EN 18031-1
- IEC 62443-4-1
- IEC 62443-4-2

SL cible

SL1 / SL2 / SL3

Notes importantes

- Ce référentiel est destiné à la pré-évaluation cybersécurité.
- Il ne remplace pas un audit certifiant officiel.
- Les exigences sont regroupées afin de couvrir un maximum d'éléments normatifs avec 20 questions.
- Les réponses pourront être converties en valeurs numériques pour le moteur IA et le calcul des Security Levels.